

AI Trust & Safety Auditing Agent

Enhanced Framework Structure (v3.1)

For AI-Based Accounting Information Systems

Prepared for: The Digital Forge

Project 1: Wenguang Li

March 2026

What's New in v3.0

- ✓ **Section 10 — Council of Experts Architecture (from v3.0)**
- ✓ **GDPR & CCPA/CPRA added as a full regulatory layer across all modules (v3.1)**
- ✓ Section 5.3 — New Privacy Regulatory Mapping table (GDPR articles + CCPA sections per module)
- ✓ Section 8.3 — New Module 3 GDPR & CCPA evidence template (ROPA, DPIA, breach notification, opt-out)
- ✓ Section 7 — GDPR fine (up to 4% global turnover) and CCPA fine (\$7,500/violation) added to breach materiality
- ✓ Three-stage peer review: Independent Scoring → Cross-Module Review → Arbitrator Synthesis
- ✓ Anonymised inter-module judging with self-preference bias mitigation
- ✓ Divergence Handling Protocols (score spread > 20 pts triggers escalation)
- ✓ Final Composite Audit Scorecard with confidence-weighted materiality
- ✓ Updated Implementation Roadmap (Phase 5 added)

1. Core Architecture: The Multi-Module Ensemble

The agent operates through five specialised Expert Modules. Each module evaluates AI-based AIS from a distinct audit perspective, synthesised by a central Orchestrator with explicit coordination mechanisms. In v3.0, a Council of Experts layer (Section 10) sits above the Orchestrator, adding peer-review scoring and an Arbitrator synthesis pass.

Module	Primary Audit Objective	Key Standard Alignment
Module 1: Governance & Compliance	Verify AI policies, ethical committees, risk management, and control documentation	ISO 42001, SOX 404, NIST AI RMF GOVERN, EU AI Act Article 9
Module 2: Fairness & Bias	Detect discriminatory outcomes in AI-driven financial decisions	NIST AI RMF Fairness, Equalized Odds, Statistical Parity, EU AI Act Article 10
Module 3: Security & Privacy	Protect financial data against adversarial attacks, unauthorised access, and privacy violations	NIST AI RMF Secure & Resilient, SOC 2, ISO 27001, EU AI Act Article 15, GDPR Articles 5/25/32–34, CCPA §1798.100–99
Module 4: Explainability & Audit Trail	Ensure AI logic transparency and auditability meeting PCAOB evidence standards	PCAOB AS 1105, SHAP/LIME, GDPR Articles 13–14/22 (Right to Explanation; Automated Decision-Making), EU AI Act Articles 12–13, CCPA §1798.100 (Right to Know)
Module 5: Accuracy & Drift Monitoring	Monitor for performance degradation, model drift, and errors leading to material misstatements	NIST AI RMF Valid & Reliable, COSO Monitoring, F1-score, Precision, Recall, AUC-ROC

2. Four-Layer Logic Foundation

Layer 1: Financial Foundation ('The Accounting Truth')

Ground all findings in financial reporting standards:

- SOX 404: Internal Control over Financial Reporting
- GAAP/IFRS: ASC 606 (Revenue Recognition), ASC 815 (Financial Instruments), ASC 350-40 (Software Capitalisation)
- PCAOB Standards: AS 1105 (Audit Evidence), AS 2110 (Risk Assessment), AS 2201 (ICFR Audit), AS 2501 (Accounting Estimates)

Layer 2: AI Guardrails ('The Safety Truth')

Apply global AI governance standards:

- ISO 42001:2023 (AI Management System) — PDCA cycle with clauses 4–10
- NIST AI RMF 1.0 — GOVERN, MAP, MEASURE, MANAGE functions with 7 trustworthy characteristics
- EU AI Act (Regulation 2024/1689) — High-risk requirements (Articles 9–15) for financial AI systems
- GDPR (Regulation 2016/679) — Data protection principles (Article 5), Privacy by Design (Article 25), security obligations (Articles 32–34), automated decision-making rights (Article 22), and Right to Explanation (Articles 13–14)
- CCPA/CPRA (California Civil Code §1798.100–1798.199) — Consumer right to know, right to delete, right to opt-out of sale/sharing of personal information; applies where AI systems process California residents' financial data

Layer 3: Intersection Logic (Mapping Risk to Impact)

Translate technical AI anomalies into financial audit risks:

- Example 1: Model Drift (technical) → Misstated Bad Debt Reserves (financial impact) → GAAP ASC 815 violation → Material weakness under SOX 404
- Example 2: Algorithmic Bias in Credit Scoring (technical) → Discriminatory Lending Patterns → Fair Lending violations + NIST AI RMF fairness failure
- Example 3: Missing AI Documentation (governance gap) → Insufficient Audit Evidence per PCAOB AS 1105 → Scope limitation in external audit
- Example 4: AI System Processes Consumer Financial Data Without Consent Mechanism (privacy gap) → GDPR Article 6 lawful basis violation + CCPA opt-out failure → Regulatory fine exposure + reputational risk

Layer 4: Regulatory Mapping Matrix

Explicit mapping matrix showing how each module criterion addresses specific regulatory requirements. See Section 5 for complete implementation.

3. Operational Audit Procedures (Iqbal Checklist Integration)

Detailed investigative steps derived from the Kamran Iqbal AI Audit Checklist, organised by module:

Module	Key Question	Check Method	Pass Criteria
A. Governance Audit (Module 1)	Does the organisation have a documented AI governance framework?	Review AI policies, RACI charts, ethics committee minutes, SOX 404 control documentation	Board-approved AI policy exists, governance committee meets quarterly, RACI matrix covers all AI systems in financial processes
B. Fairness & Bias Assessment (Module 2)	Do AI-driven financial decisions exhibit systematic bias across protected demographics?	Analyse approval rates for expense approvals, credit decisions, vendor selections across gender/race/age groups; test for disparate impact	Demographic parity within 5% across protected groups, equalized odds metrics meet fairness thresholds, training data representativeness confirmed
C. Security & Data Management (Module 3)	Are AI model weights and datasets secured in cloud environments via encryption?	Analyse cloud security configurations, encryption settings, access logs, penetration testing results, adversarial robustness tests	AES-256 encryption enabled, RBAC implemented, adversarial attack testing passed, no unauthorised access in logs
D. Explainability & Audit Trail (Module 4)	Can external auditors understand AI-driven accounting decisions sufficiently to comply with PCAOB AS 1105?	Review SHAP values, LIME explanations, model cards, audit trail logs; test whether explanations enable auditors to trace decisions to source data	Explanations enable decision traceability, model cards meet ISO 42001 documentation standards, audit trail captures all AI decisions
E. Accuracy & Drift Monitoring (Module 5)	Are AI models validated against real-world datasets to prevent overfitting and detect drift?	Review confusion matrices, performance trends, retraining logs, drift detection alerts, validation against holdout datasets	Model accuracy meets materiality-based thresholds, drift detection operational, retraining procedures documented

4. Successful Delivery Criteria

1. Materiality-Based Reporting

Indicate potential dollar-value impact of identified risks. Translate technical findings into financial statement impact using the Materiality Calculation Framework (Section 7).

2. Traceability

Cite specific source documents (e.g., “AI Policy Document v2.3, Page 4, Section 2.1”). All findings must reference evidence meeting PCAOB AS 1105 standards.

3. Human-in-the-Loop (HITL)

Escalate ‘Material Weakness’ findings for human review. The Orchestration layer surfaces disagreements and high-severity findings to human auditors rather than forcing automated resolution.

4. Regulatory Compliance Coverage

Demonstrate comprehensive coverage of SOX 404, PCAOB, GAAP, NIST AI RMF, ISO 42001, EU AI Act, GDPR, and CCPA/CPRA using the Regulatory Mapping Matrix (Section 5).

5. Council of Experts Scorecard (v3.0 addition)

Each audit report must include the Council Scorecard (see Section 10.7), showing per-module scores, peer-review grades, Arbitrator composite score, and divergence flags.

5. Regulatory Mapping Matrix

LAYER 4: This matrix explicitly shows how each module evaluation criterion maps to specific regulatory requirements, enabling automated compliance gap analysis.

5.1 Module 1: Governance & Compliance Regulatory Mapping

Evaluation Criterion	SOX 404	NIST AI RMF	ISO 42001	EU AI Act
AI Governance Policy exists and is board-approved	Control Environment	GOVERN 1.1, 1.2	Clause 5.2	Article 9
Risk Management System for AI throughout lifecycle	Risk Assessment	MAP 1.1, 1.2, 1.3	Clause 6.1	Article 9
AI Control Documentation meets SOX 404 standards	Control Activities	GOVERN 4.1	Clause 7.5	Article 11
Stakeholder Engagement mechanisms operational	Information & Communication	GOVERN 5.1	Clause 4.2	N/A
AI System Inventory maintained	Information & Communication	GOVERN 1.6, MAP 1.5	Clause 7.5	Article 11
AI Training & Competency programs	Control Environment	GOVERN 2.2	Clause 7.2	N/A
Third-Party AI Risk Management	Risk Assessment	GOVERN 6.1, 6.2	Clause 6.1	N/A
Continuous Monitoring mechanisms	Monitoring Activities	GOVERN 1.5, MEASURE 2.7	Clause 9.1	N/A

5.2 Complete Mapping for All Modules

Similar regulatory mapping matrices apply for Modules 2–5:

- Module 2: Fairness criteria → NIST Fairness characteristic, NIST SP 1270, EU AI Act Article 10, GDPR Article 9 (special category data / protected attributes), CCPA §1798.100 (right not to be discriminated against)
- Module 3: Security criteria → NIST Secure & Resilient, ISO 27001, EU AI Act Article 15, GDPR Articles 5/25/32–34 (data security, Privacy by Design, breach notification), CCPA §1798.100–99 (data security, breach liability)
- Module 4: Explainability criteria → PCAOB AS 1105, NIST Explainable & Interpretable, EU AI Act Articles 12–13, GDPR Articles 13–14/22 (transparency, automated decision-making), CCPA §1798.100 (right to know about AI-driven decisions)
- Module 5: Accuracy criteria → NIST Valid & Reliable, COSO Monitoring, GAAP ASC 606/815 reasonableness, GDPR Article 5(1)(d) (data accuracy principle), CCPA §1798.106 (right to correct inaccurate personal information)

5.3 Privacy Regulatory Mapping: GDPR & CCPA/CPRA

This supplementary matrix maps each module's evaluation criteria to the specific GDPR articles and CCPA/CPRA sections that apply. These privacy regulations are increasingly relevant to AI-based AIS because such systems process large volumes of personal financial data and make or influence consequential automated decisions about individuals.

Applicability note: GDPR applies to processing of personal data of EU residents regardless of where the organisation is based. CCPA/CPRA applies where the AI system processes personal information

of California residents. For organisations operating across jurisdictions, both frameworks may apply simultaneously to the same AI-AIS system.

Module	Key Criterion	GDPR Reference	CCPA/CPRA Reference
M1: Governance & Compliance	AI system inventory & data processing records	Article 30 — Records of Processing Activities (ROPA); Article 35 — Data Protection Impact Assessment (DPIA) for high-risk AI	§1798.100 — Right to know what personal information is collected; organisations must maintain records of AI data processing activities
M1: Governance & Compliance	Governance policy covers privacy obligations	Article 24 — Controller responsibility; Article 37–39 — DPO appointment and tasks where applicable	§1798.130 — Business obligations to implement and maintain reasonable security; privacy policy must disclose AI data use
M2: Fairness & Bias	Protected demographic attributes in AI training data	Article 9 — Processing of special category data (race, health, political opinions) requires explicit consent or legal basis	§1798.125 — Non-discrimination: businesses cannot deny services or charge different prices based on exercise of CCPA rights
M2: Fairness & Bias	Disparate impact analysis across demographic groups	Recital 71 — Prohibits discriminatory effects of automated processing; Article 22 — Right not to be subject to solely automated decisions	§1798.185 — CPRA regulations address automated decision-making technology; consumers may request opt-out
M3: Security & Privacy	Encryption and access controls for AI model data	Article 32 — Security of processing: pseudonymisation, encryption, confidentiality, integrity, resilience; Article 25 — Privacy by Design and by Default	§1798.150 — Private right of action for data breaches resulting from failure to implement reasonable security; AES-256 encryption standard applies
M3: Security & Privacy	Data breach detection and notification	Articles 33–34 — Breach notification to supervisory authority within 72 hours; notification to affected individuals without undue delay	§1798.150 — Breach notification obligations; §1798.82 (California) — Notification to affected residents and AG for breaches >500 residents

M3: Security & Privacy	Data minimisation and retention limits	Article 5(1)(c) — Data minimisation principle; Article 5(1)(e) — Storage limitation; Article 17 — Right to erasure ('Right to be Forgotten')	§1798.105 — Right to delete personal information; businesses must delete upon verified consumer request; exceptions for security/legal obligations
M4: Explainability & Audit Trail	AI decision transparency and auditability	Articles 13–14 — Right to meaningful information about automated decision-making logic; Article 5(1)(a) — Transparency principle	§1798.100 — Right to know categories and specific pieces of personal information used; §1798.185 — Right to opt-out of automated decision-making
M4: Explainability & Audit Trail	Human review of AI-driven financial decisions	Article 22 — Right to obtain human intervention, express point of view, and contest automated decisions affecting individuals	CPRA §1798.185(a)(16) — Right to opt-out of automated decision-making technology; right to access logic and correction
M5: Accuracy & Drift Monitoring	AI model accuracy for personal data inferences	Article 5(1)(d) — Accuracy principle: personal data must be accurate and kept up to date; inaccurate data must be erased or rectified	§1798.106 — Right to correct inaccurate personal information; businesses must correct upon verified request
M5: Accuracy & Drift Monitoring	Model drift affecting personal data decisions	Article 22 + Recital 71 — Automated decisions must remain valid; model drift that degrades accuracy creates compliance risk under Article 5(1)(d)	§1798.185 — Automated decision-making regulations require businesses to ensure decisions remain accurate and non-discriminatory over time

6. Module Interdependency Protocols

NEW COORDINATION LAYER: Explicit handoff protocols where module findings trigger specific tests in other modules. In v3.0, triggered protocols are also surfaced to the Council Arbitrator as weighted context during final scoring.

6.1 Trigger-Based Handoff Protocols

#	Protocol Name	Trigger Condition	Action & Outcome
Protocol 1	Governance → Fairness Escalation	Module 1 finds missing or inadequate bias detection policy	Module 2 escalates fairness testing from standard

			sampling (10%) to comprehensive testing (50%+)
Protocol 2	Performance → Explainability Review	Module 5 detects model drift exceeding 10% accuracy degradation	Module 4 performs detailed explainability review to distinguish concept drift vs. model breakdown
Protocol 3	Security → Governance Gap Analysis	Module 3 identifies a security vulnerability (weak access controls, encryption gaps)	Module 1 investigates root cause; may upgrade finding from Control Deficiency to Material Weakness
Protocol 4	Fairness → Accuracy Correlation	Module 2 detects systematic bias in AI-driven credit decisions	Module 5 analyses whether accuracy varies across demographic groups to distinguish bias vs. model error
Protocol 5	Explainability → All Modules Validation	Module 4 finds AI system lacks adequate explainability (SHAP/LIME unavailable, model card missing)	ALL other modules flag findings as 'Lower Confidence'; Orchestrator escalates to HITL as potential PCAOB AS 1105 scope limitation

6.2 Implementation in Orchestration Layer

1. All modules execute initial evaluation in parallel
2. Orchestrator analyses findings and identifies trigger conditions
3. Triggered modules execute escalated/specialised testing
4. Orchestrator synthesises findings with full handoff traceability
5. Final report documents which protocols were triggered and their outcomes
6. [v3.0] Council of Experts receives Orchestrator summary and conducts peer-review scoring pass (Section 10)

7. Materiality Calculation Framework

FINANCIAL TRANSLATION LAYER: Systematic methodology for translating technical AI findings into financial statement materiality impact, enabling prioritisation and risk assessment aligned with audit standards.

7.1 Materiality Threshold Definitions

- Overall Materiality: Typically 0.5%–1% of total assets or 5% of pre-tax income (use lower threshold)
- Performance Materiality: 50%–75% of overall materiality (buffer for aggregation risk)
- Clearly Trivial Threshold: 3%–5% of performance materiality (individual items below this not aggregated)

7.2 Module-Specific Impact Calculation Methods

Module 5: Accuracy & Performance → Direct Financial Impact

Formula: Potential Misstatement = (Error Rate) × (Total Transaction Value Affected) × (Bias Factor)

Example: AI Revenue Recognition: 2% error rate, \$500M revenue, 3.0x bias factor = \$30M potential misstatement

Assessment: If overall materiality = \$5M, then \$30M is 6× materiality → Material Weakness

Module 2: Fairness & Bias → Indirect Financial Impact

- Regulatory Penalties: Estimate potential fines based on fair lending violations, EU AI Act penalties
- Litigation Risk: Estimate class action settlement exposure based on affected population size
- Reputation/Customer Loss: Estimate revenue impact from customer attrition
- Operational Remediation: Estimate cost to retrain models and compensate affected customers

Module 3: Security & Privacy → Breach Impact

Formula: Breach Impact = (Probability of Exploit) × (Records Affected) × (Per-Record Cost) + (Downtime Cost) + (Regulatory Fine Exposure)

Industry average: \$150–\$250 per record for financial data breaches

GDPR fine exposure: Up to €20 million or 4% of global annual turnover (whichever is higher) for serious violations under Article 83(5); up to €10 million or 2% for lesser violations under Article 83(4)

CCPA fine exposure: Up to \$2,500 per unintentional violation and \$7,500 per intentional violation; private right of action of \$100–\$750 per consumer per incident for data breaches under §1798.150

Breach notification cost: GDPR: 72-hour notification window to supervisory authority; CCPA: prompt notification to California AG and affected residents; estimated notification process cost \$50k–\$500k depending on breach scale

7.3 Aggregation and Reporting

1. Calculate individual finding materiality using module-specific formulas
2. Aggregate findings below performance materiality (risk of multiple small errors combining)
3. Flag findings exceeding overall materiality as high priority
4. Generate materiality pyramid: Clearly Trivial → Performance Materiality → Overall Materiality
5. Include dollar-impact estimates with confidence intervals
6. [v3.0] Council Arbitrator applies confidence weighting from peer-review scores to adjust materiality confidence intervals (see Section 10.7)

8. Evidence Requirements Templates

Precise specification of evidence formats, statistical confidence levels, and documentation standards ensuring PCAOB AS 1105 compliance and reproducible audits.

8.1 Module 1: Governance & Compliance

Evidence Item 1: AI Governance Policy Document

Required Format: PDF or DOCX with version control, approval signatures, effective date

Minimum Content: (1) AI system scope, (2) Governance roles & responsibilities (RACI), (3) Risk management procedures, (4) Ethics principles, (5) Compliance requirements mapping

Approval Standard: Board of Directors signature within 12 months

ISO 42001 Compliance: Must address Clause 5.2 requirements

Evidence Item 2: Control Testing Documentation

Required Format: Excel with columns: Control ID, Description, Test Procedure, Sample Size, Test Date, Tester, Exceptions, Management Response

Sample Size: Minimum 25 items for manual controls; 100% for automated controls

SOX 404 Frequency: Quarterly for key controls, annually for others

8.2 Module 2: Fairness & Bias

Evidence Item 1: Fairness Metrics Report

Required Format: JSON or CSV: Protected_Attribute, Group_A, Group_B, Metric_Name, Metric_Value, Confidence_Interval, Pass_Threshold, Result

Required Metrics: Demographic Parity, Equalized Odds, Disparate Impact Ratio, Statistical Parity Difference

Statistical Confidence: 95% confidence intervals required for all metrics

Pass Thresholds: Demographic Parity $\pm 5\%$, Disparate Impact Ratio 0.8–1.25 (per EEOC)

8.3 Module 3: Security & Privacy — GDPR & CCPA Evidence

Evidence Item: Privacy Compliance Documentation

Required Format: Structured compliance register or PDF report covering: (1) Record of Processing Activities (ROPA) per GDPR Article 30, (2) Data Protection Impact Assessment (DPIA) per GDPR Article 35, (3) Privacy policy disclosures covering AI data use

GDPR Breach Readiness: Evidence of breach detection and notification procedures: incident response plan, supervisory authority contact details, template notification letters; documentation of any prior breach notifications

CCPA Compliance: Evidence of consumer rights fulfilment procedures: opt-out mechanism, deletion request workflow, right-to-know response logs; privacy policy must disclose AI-driven data processing

Privacy by Design: Architecture documentation showing GDPR Article 25 compliance: data minimisation controls, pseudonymisation or anonymisation applied to AI training data, retention schedules and deletion logs

Pass Criteria: ROPA current and complete; DPIA completed for all high-risk AI-AIS systems; breach notification SLA ≤ 72 hours (GDPR); opt-out mechanism functional and tested (CCPA); no outstanding supervisory authority enforcement notices

8.5 Module 5: Accuracy & Performance Evidence Template

Evidence Item 1: Model Validation Report

Required Format: Technical report: confusion matrix, ROC curve, Precision-Recall curve, feature importance, out-of-sample results

Validation Dataset: Holdout set minimum 20% of total data; time-split for temporal validation

Required Metrics: Accuracy, Precision, Recall, F1-Score, AUC-ROC (all with 95% confidence intervals)

Evidence Item 2: Drift Detection Logs

Required Format: Time-series: Timestamp, Metric_Name, Metric_Value, Baseline_Value, Drift_%, Alert_Triggered, Response_Action

Alert Thresholds: >5% drift → investigation; >10% → retraining consideration; >15% → immediate model review

8.6 Evidence Collection Workflow

1. Module issues evidence request specifying: Document Type, Format, Time Period, Statistical Requirements
2. Client provides evidence with metadata: Creation Date, Author, Approver, Version, Source System
3. Module validates evidence format compliance with templates
4. Module evaluates evidence substance
5. Module documents evidence in audit workpapers with cross-reference to evaluation criteria
6. Orchestration layer aggregates evidence across modules ensuring no gaps, no redundancy
7. [v3.0] Peer-review pass: each module's evidence package is shared (anonymised) with other modules for cross-domain scrutiny (see Section 10.2, Stage 2)

9. Implementation Roadmap

This enhanced framework structure (v3.0) is ready for implementation in the following phases:

Phase	Name	Timeline	Key Deliverables
Phase 1	Framework Foundation	Weeks 1–4	Finalise JSON/YAML schemas for all 5 modules; create complete Regulatory Mapping Matrix; document all interdependency handoff protocols; define materiality calculation formulas
Phase 2	Evidence Templates	Weeks 3–5	Develop complete evidence requirement templates; create evidence collection workflow automation; build evidence validation scripts
Phase 3	Orchestration Layer	Project 2	Implement critique, arbitration, synthesis mechanisms; build handoff protocol execution engine; develop materiality aggregation and reporting; create SOC 1 Type II and SOX 404 compatible report generators
Phase 4	Testing & Validation	Projects 2 & 3	Execute module-level testing with synthetic AIS data; validate handoff protocols; test materiality calculations; verify evidence templates with client/sponsor feedback
Phase 5	Council of Experts Integration	Project 3	Implement three-stage Council protocol (Sections 10.2–10.4); build anonymisation pipeline; integrate Arbitrator scoring into report generator; calibrate divergence thresholds against human auditor benchmarks

10. Council of Experts Architecture (v3.0 — New)

10.1 Overview and Rationale

Relying on a single evaluation agent for high-stakes audit decisions introduces the same risk as a Board of Directors with one member: no cross-examination, no error correction, and no bias detection. Research on multi-agent LLM systems (Karpathy 2025; MAJ-EVAL; RADAR framework) demonstrates that ensemble approaches consistently outperform single-agent baselines, achieving higher alignment with expert human judgment, better anomaly detection, and lower hallucination rates — particularly in high-risk domains such as financial auditing.

The Council of Experts layer operationalises this insight inside the existing framework. Each of the five Expert Modules functions as a domain judge that (a) grades the audit target independently, (b) peer-reviews the findings of the other four modules from its own domain lens, and (c) provides input to an Arbitrator that synthesises a final composite score. Critically, this layer operates independently of — but is fully integrated with — the existing Orchestrator, Interdependency Protocols, and Materiality Framework.

Design principle: The Council does NOT replace the Orchestrator's workflow coordination role. The Orchestrator manages execution order and trigger protocols. The Council evaluates quality, confidence, and consistency of findings after execution. Think of the Orchestrator as the audit manager and the Council as the quality review panel.

10.2 Three-Stage Council Protocol

The Council runs as a post-Orchestrator pass in three sequential stages:

STAGE 1 — Independent Expert Scoring

Each module independently grades the AI-AIS system against its domain-specific rubric (see Section 10.3). Modules operate in parallel with no visibility of each other's outputs. This prevents early anchoring bias and ensures genuine independence of initial assessments.

Output per module:

- Domain Score (0–100) with confidence interval
- Severity classification per finding: Critical / High / Medium / Low
- Evidence confidence rating: Strong / Moderate / Weak / Insufficient
- Triggered interdependency flags (from Section 6)

STAGE 2 — Anonymised Cross-Module Peer Review

The Orchestrator anonymises each module's Stage 1 findings package, labelling them "Report A" through "Report E" with module identity removed. Each module then receives and reviews all five anonymised reports (including its own) through its domain lens. This is the critical anti-bias mechanism: research shows that removing identifiers forces evaluators to assess content rather than source reputation.

Anonymisation removes: module name, authoring agent ID, prompt templates, and any module-specific vocabulary patterns. Randomised report labels are regenerated each audit cycle.

Each module produces a Peer Review Card for each of the other four reports:

- Cross-Domain Score: 1–10 rating of the report's rigour from the reviewing module's perspective
- Domain Blind-Spot Flag: identified gaps the original module may have missed from a cross-domain view
- Consistency Check: whether the report's findings are internally consistent and free from logical contradiction
- Escalation Recommendation: Agree / Escalate Higher / Escalate Lower / Flag for Arbitration

STAGE 3 — Arbitrator Synthesis

The Arbitrator is a dedicated synthesis agent — distinct from both individual modules and the Orchestrator — whose sole role is to receive all Stage 1 scores, all Stage 2 peer-review cards, and the Orchestrator's interdependency trigger log, and produce the Final Audit Composite Score.

Arbitrator inputs:

- 5 × Domain Scores (from Stage 1)
- 20 × Peer Review Cards (5 modules × 4 peers each, from Stage 2)
- Orchestrator interdependency trigger log (from Section 6)

Arbitrator outputs:

- Final Composite Audit Score (0–100), confidence-weighted across modules
- Consensus Map: areas where ≥ 4 modules agree on severity
- Divergence Map: areas where module scores differ by ≥ 20 points (auto-escalated to HITL)
- Materiality Confidence Adjustment: narrows or widens materiality confidence intervals based on peer-review agreement level
- Council Scorecard (see Section 10.7) appended to the final audit report

10.3 Per-Module Scoring Rubric (Stage 1)

Each module applies the following structured rubric to produce its Domain Score. The rubric is domain-agnostic in structure but domain-specific in criteria content (see evidence templates, Section 8).

Score Range	Grade	Interpretation
90–100	Exemplary	All criteria met; evidence strong; no material gaps; best-practice controls observed
70–89	Satisfactory	Most criteria met; minor gaps; no material findings; corrective actions documented
50–69	Needs Improvement	Significant gaps exist; some criteria unmet; findings documented; remediation required
30–49	Deficient	Multiple criteria unmet; control deficiencies or significant deficiencies present; escalation required
0–29	Critical / Material Weakness	Pervasive failures; material weakness likely; immediate HITL escalation mandatory

Stage 1 Score Decomposition

Each Domain Score is decomposed into four sub-dimensions to enable targeted remediation:

Sub-Dimension	Weight	Scoring Basis
Evidence Quality	25%	Completeness, format compliance, audit trail strength (per Section 8 templates)
Criteria Coverage	30%	Proportion of module pass criteria met (per Section 3)
Regulatory Alignment	25%	Coverage of applicable regulatory requirements (per Section 5 mapping matrix)
Materiality Weighting	20%	Scaled by financial impact estimate (per Section 7 formulas)

10.4 Cross-Module Review Matrix (Stage 2)

This matrix defines the specific cross-domain lens each module applies when peer-reviewing another module's anonymised findings. The lens ensures that peer reviews are substantive and domain-grounded — not generic quality checks.

Reviewer Module	Report Under Review	Cross-Domain Review Lens (key questions)
M1: Governance	M2: Fairness	Is there a documented bias policy that mandates these fairness tests? Are accountability owners assigned?
M1: Governance	M3: Security	Is security policy documented and board-approved? Do findings reveal a governance gap (missing RACI, no security charter)?
M1: Governance	M4: Explainability	Does the governance framework mandate explainability standards and audit trail requirements?
M1: Governance	M5: Accuracy	Is model performance monitoring required under the governance framework? Who is accountable for drift alerts?
M2: Fairness	M1: Governance	Does the governance framework include demographic equity obligations? Are bias review procedures mandated?
M2: Fairness	M3: Security	Do access control findings suggest differential data access across demographic groups — a proxy for bias risk?
M2: Fairness	M4: Explainability	Are explanations produced equally across demographic groups? Can disadvantaged groups obtain adequate explanation?
M2: Fairness	M5: Accuracy	Does accuracy vary systematically across demographic groups? Is the model more error-prone for protected classes?
M3: Security	M1: Governance	Does the governance documentation include security controls? Are there gaps between policy and observed access controls?
M3: Security	M2: Fairness	Could adversarial manipulation of training data produce or amplify the biases identified?
M3: Security	M4: Explainability	Are explanation artifacts (SHAP logs, LIME outputs) themselves secured against tampering?
M3: Security	M5: Accuracy	Could the accuracy degradation be caused by adversarial data poisoning rather than natural model drift?
M4: Explainability	M1: Governance	Is governance documentation itself explainable and traceable? Do RACI charts map to auditable decisions?
M4: Explainability	M2: Fairness	Are fairness metrics explained to affected parties? Can auditors trace a biased decision to its root cause?
M4: Explainability	M3: Security	Are security incident responses explainable and documented to PCAOB AS 1105 evidentiary standards?
M4: Explainability	M5: Accuracy	Is performance degradation explainable? Can auditors verify why a model's accuracy has changed?
M5: Accuracy	M1: Governance	Is the governance framework's effectiveness measurable? Are governance KPIs tracked with quantifiable accuracy?
M5: Accuracy	M2: Fairness	Are fairness metrics statistically reliable? Could the sample size or methodology produce false-positive fairness conclusions?

M5: Accuracy	M3: Security	Are security test results statistically valid? Is penetration test coverage sufficient to draw accuracy-grade conclusions?
M5: Accuracy	M4: Explainability	Is explainability evidence statistically representative? Do SHAP/LIME samples reflect actual model behaviour at scale?

10.5 Divergence Handling Protocols

Score divergence between modules is not a failure of the system — it is a signal. When modules disagree significantly, this typically indicates genuine complexity, ambiguity in evidence, or a cross-domain risk that no single module fully captures. The Council treats divergence as audit-relevant information rather than noise to be averaged away.

Divergence Level	Score Spread	Status	Protocol Action
Low Divergence	< 10 pts	Normal	No special action; Arbitrator uses standard weighted average
Moderate Divergence	10–19 pts	Noteworthy	Arbitrator documents the disagreement; identifies which dimension drives the gap; includes explanatory note in Scorecard
High Divergence	20–34 pts	Significant	Automatic HITL escalation; Arbitrator must provide a written reconciliation; finding severity upgraded one level
Critical Divergence	≥35 pts	Critical	Automatic suspension of automated scoring; mandatory human auditor review before any finding is finalised; potential scope limitation flag per PCAOB AS 1105

Root Cause Categories for Divergence

When divergence occurs, the Arbitrator classifies the root cause from the following taxonomy to guide resolution:

Root Cause Category	Description and Resolution Path
Evidence Gap	One module had access to stronger evidence than others. Resolution: re-run that module's test with shared evidence base.
Scope Disagreement	Modules interpreted the audit scope boundary differently. Resolution: Orchestrator clarifies scope; modules re-score within agreed boundary.
Genuine Cross-Domain Risk	The finding sits at the intersection of two domains and each module is partially correct. Resolution: Arbitrator creates a joint finding citing both modules; HITL reviews.
Self-Assessment Inflation	One module's self-score diverges upward from peer assessments of its own findings — potential self-preference bias. Resolution: Arbitrator discounts self-score; flags for calibration review.
Threshold Difference	Modules apply different numerical thresholds for the same criterion (e.g., 5% vs. 10% drift). Resolution: Orchestrator enforces global threshold table; re-score.

10.6 Integration with Existing Architecture

The Council of Experts is designed as a modular, additive layer. All pre-existing components operate unchanged. The Council consumes their outputs without modifying the underlying module logic, evidence templates, or regulatory mapping. The integration points are as follows:

Existing Component	Integration Point
Section 3: Operational Audit Procedures	Module pass/fail criteria become the Stage 1 scoring inputs. No changes to procedures required.
Section 5: Regulatory Mapping Matrix	Stage 2 peer reviewers use the regulatory mapping to identify cross-domain compliance gaps. The matrix is read-only input to the Council.
Section 6: Interdependency Protocols	Triggered protocol outcomes are forwarded to the Arbitrator as weighted context. High-severity triggers increase the Arbitrator's divergence sensitivity threshold by one level.
Section 7: Materiality Framework	Arbitrator's confidence-weighted composite score adjusts materiality confidence intervals. High peer-review consensus narrows intervals; high divergence widens them.
Section 8: Evidence Templates	Stage 2 peer review introduces a new evidence artifact: the Peer Review Card. This is appended to the audit workpaper alongside the original module evidence package.
Section 9: Implementation Roadmap	Council of Experts is implemented in Phase 5. Phases 1–4 remain unchanged and are prerequisites.

10.7 Council of Experts Scorecard — Output Template

Every audit engagement that runs the Council of Experts produces a standardised Scorecard appended to the final audit report. This is the single-page summary of the full three-stage process. Below is the defined template structure:

COUNCIL OF EXPERTS — FINAL AUDIT SCORECARD				
M1: Governance	M2: Fairness	M3: Security	M4: Explainability	M5: Accuracy
[Stage 1 Score] CI: [±x pts] Avg. Peer Score: []	[Stage 1 Score] CI: [±x pts] Avg. Peer Score: []	[Stage 1 Score] CI: [±x pts] Avg. Peer Score: []	[Stage 1 Score] CI: [±x pts] Avg. Peer Score: []	[Stage 1 Score] CI: [±x pts] Avg. Peer Score: []
Arbitrator Composite Score		Divergence Status		Materiality Confidence
[0–100] Confidence-Weighted		[Low / Moderate / High / Critical] Max spread: [x pts] on [dimension]		[Narrow / Standard / Wide] Adjusted from ±[x]% to ±[y]%
Escalation Flags & Key Findings				
HITL Escalation: [List of findings requiring human review] Consensus Findings: [Areas where ≥4 modules agree on severity] Divergence Findings: [Specific findings with score spread ≥20 pts and root cause category] Interdependency Triggers Activated: [List of Section 6 protocols triggered and their Council impact]				

10.8 Known Limitations and Mitigations

The Council architecture addresses several well-documented failure modes in multi-agent evaluation systems. The following limitations are acknowledged and mitigated:

Limitation	Risk Description	Mitigation
Self-Preference Bias	Modules may rate their own findings more favourably than peers rate them	Anonymisation in Stage 2 removes module identity. Arbitrator flags self-score outliers as potential bias; discounts self-scores above peer average by >15 pts.
Length/Verbosity Bias	More verbose module reports may receive higher peer scores regardless of quality	Peer review rubric scores four defined sub-dimensions (Section 10.3). Length is not a rubric criterion.
Cascading Errors	Stage 2 peer reviews are based on Stage 1 outputs; if Stage 1 is systematically wrong, all stages inherit the error	Evidence templates (Section 8) provide an independent ground truth layer. Peer reviews must cite specific evidence gaps, not just scores.
Convergence / Group-think	Repeated peer review cycles can cause modules to converge toward a median, losing diversity	The Council runs only two stages (not iterative debate). One-shot peer review preserves diversity while still catching errors.

Latency Cost	Running 5 modules × 5 peer reviews × 1 Arbitrator = 31 agent calls per audit cycle	Stage 2 peer reviews run in parallel. Estimated overhead vs. single-pass: +40–60% compute cost; justified for high-risk AI systems.
---------------------	---	---